

TwinaForms ZAP ISV Response

Date: 2026-06-05

Scope: OWASP ZAP Automation Framework requestor scans for public TwinaForms form hosting and AWS runtime endpoints. The official reports listed below are passive requestor evidence scans. Protected routes are intentionally scanned without bearer/JWT credentials to prove unauthenticated rejection. Active attack scans were also run internally against these endpoints and produced no High-risk, injection, or XSS findings.

Release context: scans were rerun after releasing TwinaForms managed package 0.10.0.5. The prior X-Content-Type-Options Header Missing endpoint finding remains absent from the refreshed endpoint reports.

Official reports to attach with this response:

- Report 01: published form page
- Report 02: prefill Lambda
- Report 03: submit Lambda
- Report 04: Salesforce backend Lambda
- Report 05: submission logs Lambda
- Report 06: admin API Cognito-protected Lambda

`01-published-form-page.html`

Content Security Policy (CSP) Header Not Set

Classification: Accepted hardening item.

The published form is a static generated HTML page served from S3/CloudFront. The current response includes managed security headers such as X-Content-Type-Options: nosniff and Strict-Transport-Security: max-age=31536000, which are visible in the ZAP report evidence.

TwinaForms treats browser-rendered form content as the relevant risk area for this CSP finding. The Salesforce publisher encodes generated HTML values, escapes JavaScript string values, normalizes supported input types, and avoids appending configured custom JavaScript as raw trailing script markup. Runtime merged-document values are also escaped before they are inserted into generated browser HTML. These controls reduce XSS exposure in the generated page.

A stricter CSP remains a launch hardening item because generated customer forms can include optional browser features such as CAPTCHA, customer styling, external image resources, and customer-approved custom JavaScript. A baseline CSP, initially in report-only mode if needed for compatibility, is planned as browser-side hardening. This finding does not show exposed Salesforce data, tokens, credentials, tenant secrets, or authentication bypass. Runtime prefill and submit operations are still validated server-side with the published form token and configured form policies.

Sub Resource Integrity Attribute Missing

Classification: Accepted hardening item for external browser resources.

The published form can include external browser resources for supported form features. The finding is about browser resource hardening, not about exposed secrets or broken server-side access control. The generated form does not rely on Subresource Integrity for authentication or tenant trust.

Future hardening option: pin external script versions and add SRI where the provider and runtime configuration make stable hashes practical.

Cross-Domain JavaScript Source File Inclusion

Classification: Expected browser behavior for supported third-party services.

Published forms may load approved third-party browser resources, for example CAPTCHA provider scripts. These scripts are used for client-side form features only. They do not receive Salesforce credentials, tenant bearer secrets, AWS secrets, or OAuth refresh tokens.

Server-side operations remain controlled by the TwinaForms runtime, publish tokens, form id checks, and tenant policies.

Server Leaks Version Information via `Server` HTTP Response Header Field

Classification: Expected infrastructure header.

The response includes an AWS infrastructure Server header because the published form is hosted through AWS-managed infrastructure. This identifies the hosting service but does not expose application version numbers, source paths, credentials, tenant data, or Salesforce data.

Information Disclosure - Sensitive Information in URL

Classification: Expected test input and accepted product behavior for this demo form.

The tested URL intentionally includes email=liam.carter@example.com to exercise the public prefill flow. This is sample data and is not a password, OAuth token, API key, tenant secret, or AWS secret.

TwinaForms allows form administrators to configure prefill links. A lookup value such as an email address can be used when that is the intended form design. The browser cannot use that URL parameter to choose arbitrary Salesforce objects, fields, or queries. The prefill endpoint validates the published form token and rejects unexpected parameters.

For forms with more sensitive lookup values, the recommended form design is to avoid sensitive identifiers in URLs or use stronger verification before showing sensitive data.

Modern Web Application

Classification: Informational.

The published form is a JavaScript-enabled public web form. This is expected and does not indicate a vulnerability by itself.

Re-examine Cache-control Directives

Classification: Accepted operational behavior.

The published form uses conservative cache behavior so recently republished forms and setup changes are not hidden by stale browser or CDN content during customer onboarding and launch testing. The finding does not show credential exposure or access-control failure.

`02-prefill-lambda.html`

Cross-Domain Misconfiguration

Classification: Accepted runtime behavior.

The prefill Lambda accepts cross-origin browser calls because published forms are static pages hosted separately from the Lambda Function URL. The endpoint does not rely on cookies or browser credentials. It requires the per-form public publish token, validates the form id, rejects unexpected parameters, and returns only fields mapped by the form designer for that published form.

The current ZAP plan includes rejection cases for missing token, invalid token, and unexpected parameters.

Strict-Transport-Security Header Not Set

Classification: Accepted AWS Lambda Function URL limitation/hardening item.

The Lambda Function URL is an AWS-managed HTTPS endpoint. Salesforce and browser traffic use HTTPS. The missing HSTS header is a response-header hardening item on the AWS-managed Lambda URL domain, not evidence of plaintext transport.

If the endpoint is later placed behind a custom CloudFront/API Gateway domain, HSTS can be added there.

`03-submit-lambda.html`

Cross-Domain Misconfiguration

Classification: Accepted runtime behavior.

The submit Lambda must accept browser calls from published TwinaForms forms. The endpoint does not use cookies for authentication. It validates the per-form publish token, form id, and configured submit policy before writing to Salesforce.

The current ZAP plan uses safe rejection cases and does not create Salesforce records.

Strict-Transport-Security Header Not Set

Classification: Accepted AWS Lambda Function URL limitation/hardening item.

The endpoint is served over HTTPS. The missing HSTS header is a response-header hardening item on the AWS-managed Lambda URL domain.

`04-salesforce-backend-lambda.html`

Cross-Domain Misconfiguration

Classification: Accepted behavior for this scan context.

Some backend responses include permissive CORS headers. CORS is not used as an access-control mechanism; protected routes require the tenant bearer secret used by Salesforce callouts. The ZAP plan intentionally sends missing-auth requests and verifies that protected routes reject unauthenticated access.

No tenant bearer secret is included in the report.

Strict-Transport-Security Header Not Set

Classification: Accepted AWS Lambda Function URL limitation/hardening item.

The endpoint is HTTPS-only from the Salesforce package perspective. The missing HSTS header is a response-header hardening item on the AWS-managed Lambda URL domain.

Re-examine Cache-control Directives

Classification: Informational.

The backend endpoint returns JSON operational responses. Caching is not used as an access control mechanism. Protected routes require tenant bearer authentication.

`05-submission-logs-lambda.html`

Cross-Domain Misconfiguration

Classification: Accepted behavior for this scan context.

The submission logs Lambda is called by Salesforce with tenant bearer authentication. The ZAP plan sends missing-auth requests and verifies that routes reject unauthenticated access. No tenant bearer secret is included in the report.

Strict-Transport-Security Header Not Set

Classification: Accepted AWS Lambda Function URL limitation/hardening item.

The endpoint is served over HTTPS. The missing HSTS header is a response-header hardening item on the AWS-managed Lambda URL domain.

`06-admin-api-cognito.html`

Strict-Transport-Security Header Not Set

Classification: Accepted AWS Lambda Function URL limitation/hardening item.

The Admin API is protected by Cognito JWT validation. The ZAP plan sends requests without a Cognito token and verifies that the API rejects them with 401 Unauthorized.

The missing HSTS header is reported on the AWS-managed Lambda Function URL. The admin web console itself is hosted on admin.twinaforms.com and uses Cognito Hosted UI login. A future API Gateway or custom CloudFront/API domain can add HSTS to the API response layer.

Reviewer Disposition

The ZAP findings are either expected public-form behavior, AWS-managed endpoint header limitations, or hardening items. The scans confirm that protected tenant/backend/admin routes reject unauthenticated requests and that the public prefill/submit endpoints enforce publish-token and form-policy validation.